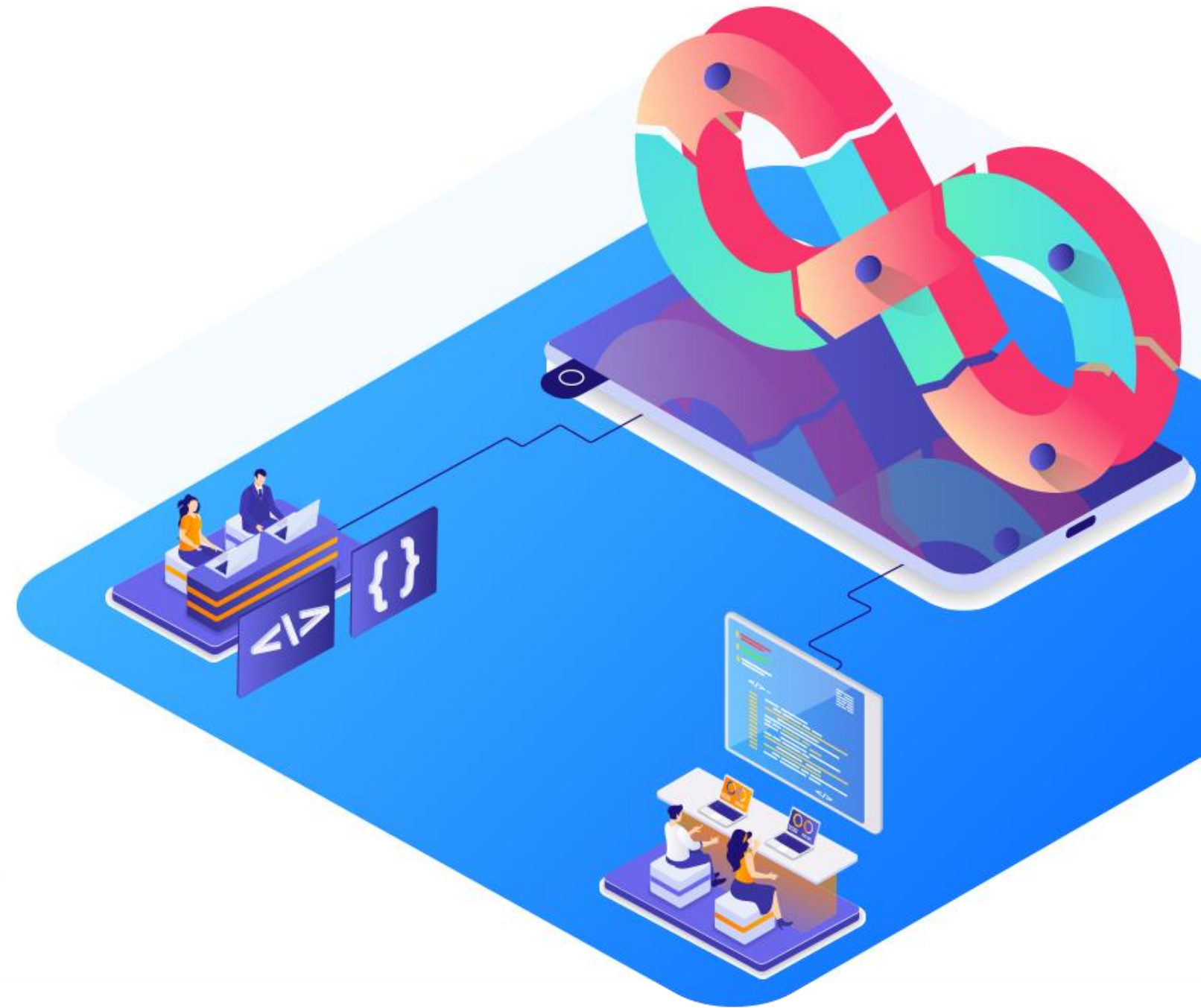
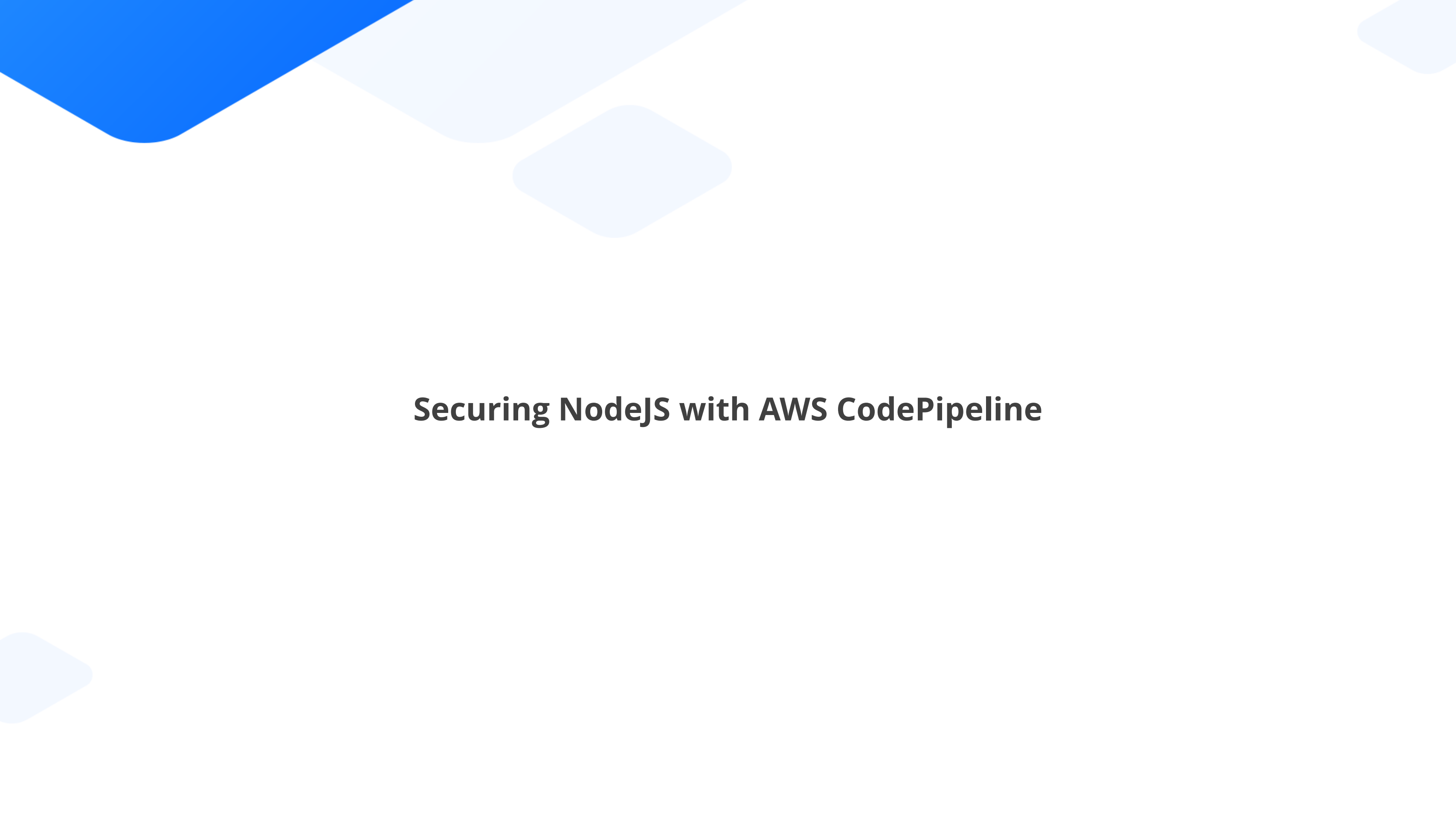


DevSecOps: Principles and AWS Cloud Security



Course-End Project





Securing NodeJS with *AWS* CodePipeline

Objective

To create a GitHub action workflow that will scan and perform SCA, SAST, and penetration security testing on a NodeJS source code



Problem Statement and Motivation



Real-time scenario:

CloudInnovate, a startup focused on developing cloud applications for small business customer data management, uses GitHub for version control and prioritizes high security due to the sensitive data involved.

To bolster security, CloudInnovate automates checks via GitHub Actions, including cloning their NodeJS app, confirming build integrity, and performing security scans.

They employ Snyk for Static Application Security Testing (SAST) and Software Composition Analysis (SCA) to find vulnerabilities, and OWASP ZAP for penetration tests. Results are directly logged in GitHub, ensuring swift issue resolution. This strategy not only secures their software but also boosts their reputation, making them more attractive to investors.

Industry Relevance

The following tools used in this project serve specific purposes within the industry:

1. **AWS CodePipeline:** It automates the software release process to ensure fast and secure deployments, integrates seamlessly with security tools for DevSecOps workflows, and reduces manual intervention while enhancing reliability.
2. **Snyk:** It detects vulnerabilities in code and third-party libraries using SAST and SCA techniques, helping teams address security issues early in the development process and ensuring continuous security within the pipeline.
3. **OWASP ZAP:** It performs penetration testing, such as spidering and active scans, to detect web application vulnerabilities, making it a widely used tool for ensuring secure deployments, with its reports being essential for identifying risks before production.



Industry Relevance

The following tools used in this project serve specific purposes within the industry:

5. **GitHub:** It offers a platform for source code management and collaboration, seamlessly integrating with CI/CD tools for automated testing and builds, thereby enabling secure and efficient development.
6. **AWS CodeBuild:** It compiles code, executes tests, and generates build artifacts while incorporating security checks during the CI/CD process, ensuring high-quality builds and supporting safer software delivery.



Tasks

The following tasks outline the process of implementing security to NodeJS with AWS Pipeline:

1. Fork repository and update configuration
2. Create AWS CodePipeline
3. Implement SCA and SAST scans
4. Perform DAST scans with OWASP ZAP
5. Integrate stages in CodePipeline
6. Validate and review results



Project References

- **Task 1:** Lesson 01
- **Task 2:** Lesson 02
- **Task 3:** Lesson 01
- **Task 4:** Lesson 01
- **Task 5:** Lesson 02
- **Task 6:** Lesson 03

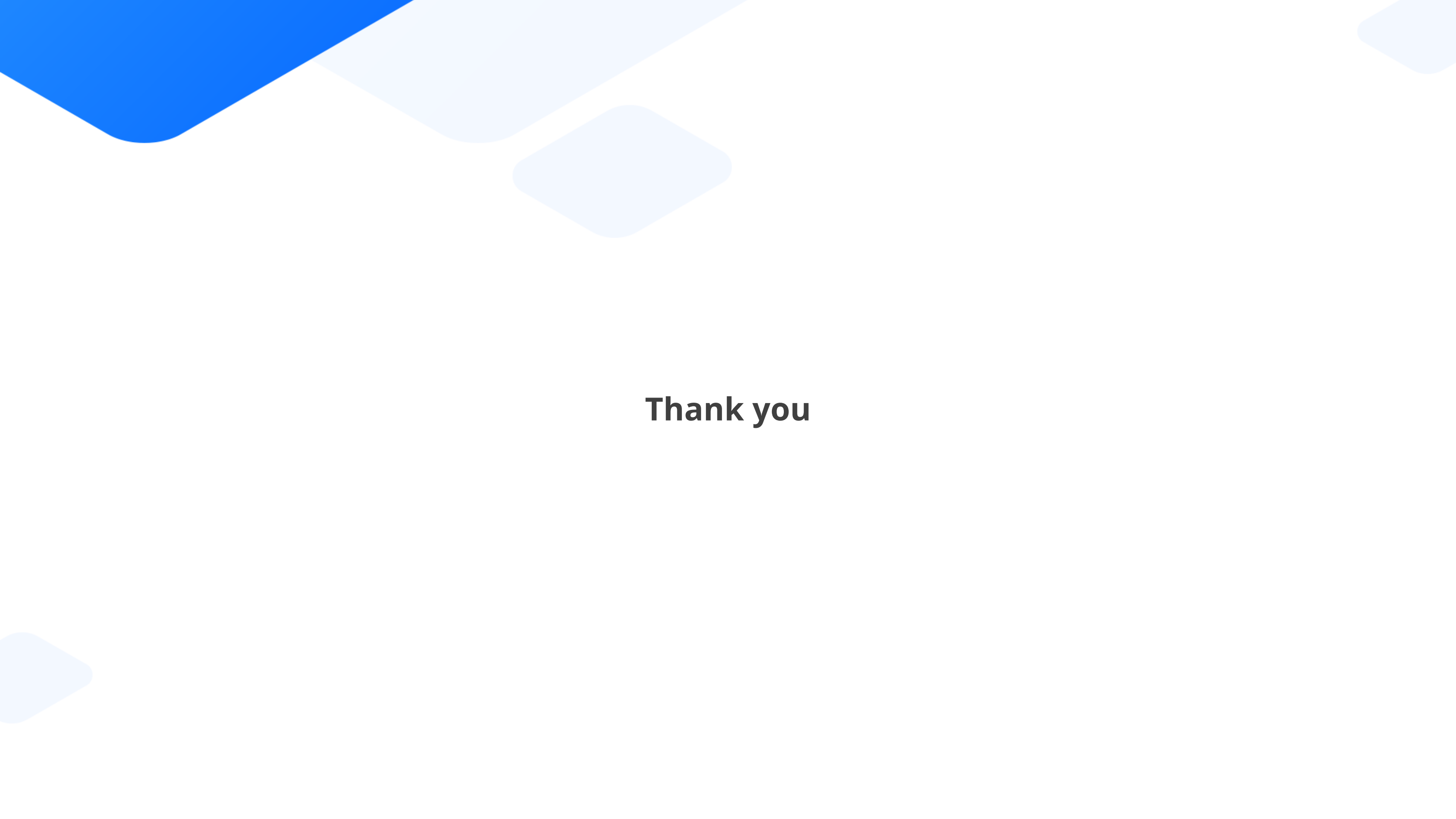


Output Screenshots

DevSecOps pipeline is successfully executed, storing Snyk and OWASP ZAP scan reports in the Amazon S3 bucket as shown below:

The screenshot displays the Amazon S3 console interface. The left sidebar shows the 'Amazon S3' service with various navigation options. The main content area shows the bucket 'codepipeline-us-east-2-265331847207'. The 'Objects' tab is selected, showing a list of objects. The list includes a folder named 'devSecops-Pipeline/' and a file named 'ZAPscan'. The 'ZAPscan' file is 19.6 KB and was last modified on November 12, 2024, at 13:52:28 (UTC+05:30).

☐	Name	Type	Last modified	Size	Storage class
☐	devSecops-Pipeline/	Folder	-	-	-
☐	ZAPscan	-	November 12, 2024, 13:52:28 (UTC+05:30)	19.6 KB	Standard



Thank you